

Avisos, auditoria e segurança

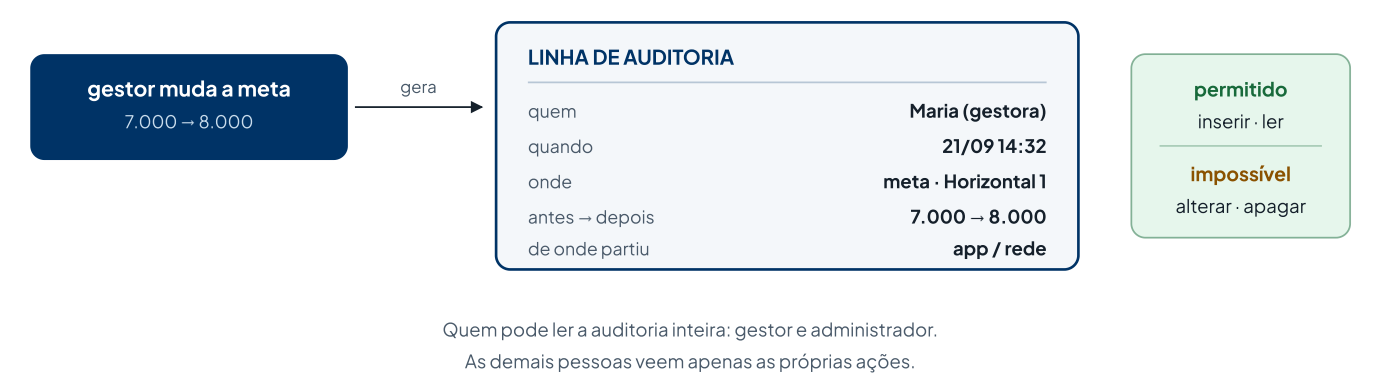
A parte que ninguém abre quando tudo está bem — e a única que serve quando alguém pergunta "quem mudou isso?".

1. A auditoria é um livro de tinta permanente

Analogia: é o **livro de ocorrências da portaria**. Você escreve, assina e não arranca folha. Se errou, escreve embaixo que errou — a linha anterior fica.

Toda escrita importante no banco gera uma linha nessa tabela: quem fez, quando, em que ficha, e **como estava antes e como ficou depois**. Os dois lados são guardados, porque "a meta mudou" sem o valor antigo não explica nada.

A regra mais forte do sistema está aqui: **ninguém pode alterar nem apagar uma linha da auditoria**. Nem o administrador. A permissão existe só para escrever e para ler; não há política que permita mexer no que já foi escrito.



A auditoria não é opcional nem "modo debug": é o que sustenta qualquer conversa sobre número divergente, meta alterada ou apontamento corrigido.

2. Os avisos

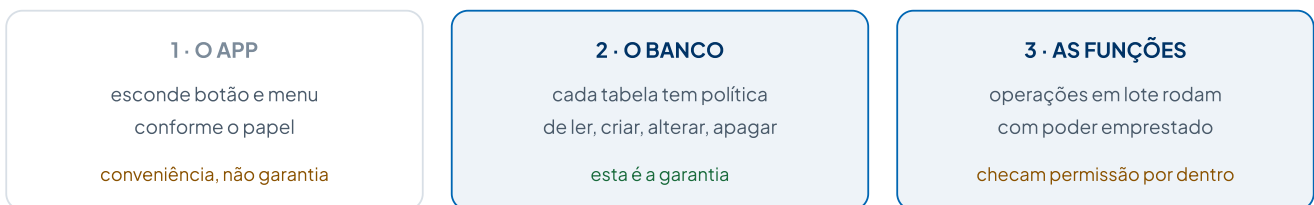
Analogia: é o **recado no vidro da sala**: fica lá até alguém ler e tirar. Não é e-mail, não é mensagem — vive dentro do sistema.

Hoje o uso principal é o cadastro pendente: quando alguém se cadastra, o gestor e o administrador recebem um aviso para aprovar. O aviso guarda quem recebe, o texto, o tipo, um destino (a tela de usuários) e se já foi lido.

Cada pessoa só vê os avisos dela, e só ela pode marcar como lido. Quem cria aviso é o próprio banco, num gatilho: ao aparecer perfil pendente, os avisos são gerados sem o app precisar lembrar de fazer isso.

Trade-off do gatilho: ganha que nunca esquece, mesmo se o cadastro vier por outro caminho. Custa que a lógica fica em dois lugares (banco e app), e quem depurar precisa saber que o banco também age por conta.

3. As três camadas de segurança



Tirar a camada 1 deixa a interface feia. Tirar a camada 2 abre o banco para qualquer pessoa com a chave pública. Por isso as políticas foram testadas tentando, de propósito, furar cada uma delas.

A segurança real está na camada 2. A camada 1 existe para a pessoa não bater numa porta trancada.

A camada 3 merece uma palavra. Algumas operações — alterar 200 apontamentos de uma vez, consultar dados de outra pessoa para checar permissão — precisam de mais poder do que a pessoa tem. Essas funções recebem esse poder emprestado, e por isso três cuidados foram tomados: elas **verificam a permissão por dentro** antes de agir, têm o **caminho de busca fixo** (ninguém consegue enganá-las criando uma tabela com nome parecido), e nunca aceitam texto que vá direto para dentro de uma consulta.

4. Uma falha que os testes pegaram

Analogia: a regra dizia "pode editar se você for o autor". Para um apontamento **sem autor**, a resposta não era "não" — era "**não sei**". E "não sei" estava deixando passar.

Acontece com os apontamentos importados e os de demonstração, que não têm autor. A verificação devolvia um valor indefinido em vez de uma negativa, e o banco tratava isso como liberação. Um operador conseguia editar apontamento que não era dele.

A correção foi de uma linha: quando a resposta é indefinida, vale **não**. Antes de corrigir, foi escrito um teste que reproduz a falha — ele reprovou, a correção entrou, e ele passou. Está na versão 0.10.3 do banco.

É por isso que existem os 47 testes automáticos (24 de funções, 23 de políticas). Eles rodam dentro de uma transação que é sempre desfeita no fim: testam no banco real sem deixar nada para trás.

5. O que este caderno não cobre

Limpeza da auditoria

A tabela só cresce. Um dia vai precisar de arquivamento — mover o antigo para outro lugar, nunca apagar. Ainda não é problema.

Aviso fora do sistema

Nada sai por e-mail ou WhatsApp. Quem não abrir o sistema não fica sabendo do cadastro pendente.

Painel de auditoria

Os dados estão lá, mas não há tela para consultá-los. Hoje só por consulta direta ao banco.

Backup e restauração

Vem do plano do Supabase e não foi configurado nem testado neste projeto de testes.

6. Fechando os seis cadernos

CADERNO	EM UMA FRASE
1 · Visão geral	Quatro áreas, e o apontamento no centro de tudo
2 · Máquinas e metas	A meta tem linha do tempo, e o passado não é reescrito
3 · Apontamentos	Capa e folhas; retrabalho e hora extra fora da meta
4 · Calendário	Separar "não rodou" de "rodou mal"
5 · Pessoas	Permissão, não cargo; cadastro aprovado por alguém
6 · Auditoria	O que foi escrito não se apaga

Se algo aqui não corresponde ao seu dia a dia na fábrica, é sinal de que o desenho está errado — não o dia a dia. Vale registrar como decisão nova em `docs/database/03-decisoes.md`.